PENTESTING PROJECT REPORT

FOOTPRINTING, OSINT & NETWORK SCANNING PHASES

W2 | CYBERSECURITY | NETWORKWALKS

Pentester Name	Sheila Chepkoech
Program/Batch	B084-Networkwalks
Date	9 November 2026
Modules completed	W2-PM1 (Footprinting with Multiple Kali Tools) W2-PM3 (Footprinting with Maltego) W2-PM4 (Footprinting with theHarvester) W2-PM5 (Network Scanning with Zenmap)
Client/Target	1. networkwalks.com (course-assigned target, W2-PM1 & W2-PM3) 2. microsoft.com (course-assigned target, W2-PM4) 3. My own local LAN network (W2-PM5)
Permission secured from client?	Yes — course-assigned educational targets, plus own-owned network for active scanning
Phases covered	Phase 1: Reconnaissance & Footprinting (passive — PM1, PM3, PM4) Phase 2: Scanning & Network Discovery (active, own network only — PM5) Phase 1b (GHDB/OSINT via search engine — PM2): Not yet completed Phase 3–5: In Progress

1. Liability Disclaimer

I have performed these activities only on the systems and devices where I had secured permission as part of an assigned educational course, or on devices/networks that I own myself. All materials and activities described in this report are for education and research purposes only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what I do with this knowledge. Every action I take is my own responsibility. Misuse can lead to criminal charges, heavy fines, loss of employment and a permanent record. In most countries, unauthorised access is a crime even when nothing is damaged.

2. Introduction

This report covers four Week 2 modules of my Cybersecurity & Ethical Hacking internship at Networkwalks. Three modules covered the footprinting and OSINT (open-source intelligence) phase, using different tools and techniques against two course-assigned targets, and one module covered the active scanning phase against my own local network.

Specifically: W2-PM1 used six built-in Kali Linux command-line tools to footprint networkwalks.com. W2-PM3 used Maltego, a graphical OSINT and link-analysis tool, to find email addresses linked to the same domain. W2-PM4 used theHarvester to gather email addresses and sub-domains for a second assigned target, microsoft.com. W2-PM5 used Zenmap, the graphical front-end for Nmap, to discover live hosts on my own home LAN.

Together, these modules show the breadth of the footprinting phase: command-line tools, a dedicated OSINT graphing platform, and an automated harvesting tool, all gathering different but overlapping types of information, followed by active host discovery once reconnaissance is complete. Every step below includes the exact command or action used, the result observed, a screenshot as evidence, and a short note on why the finding matters from an attacker's point of view.

3. Tools Used

The table below lists each tool used across the four modules and its purpose.

Tool	Module	Purpose
Kali Linux	W2-PM1	Operating system used for command-line reconnaissance
WHOIS	W2-PM1	Find domain registration details (owner, dates, name servers)
WhatWeb	W2-PM1	Fingerprint web technologies (server, CMS, plugins, IP)
Nslookup	W2-PM1	Resolve the domain name to its IP address using DNS
Curl -I	W2-PM1	Read the HTTP response headers of the website
Wafw00f	W2-PM1	Detect whether a Web Application Firewall protects the site
DNSRecon	W2-PM1	Enumerate all DNS records (NS, MX, SPF, TXT, SRV)
Maltego Graph (Desktop)	W2-PM3	Graph-based OSINT tool; ran Utilities transforms to find linked email addresses
theHarvester	W2-PM4	Automated OSINT tool to gather emails, hosts and IPs from public sources

Zenmap (Nmap GUI)	W2-PM5	Scan the local subnet to find live hosts, IPs and MAC addresses
Windows CMD (ipconfig)	W2-PM5	Local IP address, subnet and MAC address identification

4. Activities Performed

4.1 Footprinting & Reconnaissance with Kali Tools (W2-PM1)

I performed reconnaissance against the networkwalks.com domain using six Kali Linux tools: WHOIS, WhatWeb, Nslookup, Curl, Wafw00f and DNSRecon. Each tool was used to collect a different type of information about the target.

First, I used WHOIS to obtain publicly available domain registration information. The domain is registered via GoDaddy.com, LLC, created on 2019-11-06 and set to expire 2027-11-06, with name servers pointing to HostGator (NS6135/NS6136.HOSTGATOR.COM) and GoDaddy's own DomainControl servers. WHOIS privacy (Domains By Proxy, LLC) hides the actual registrant, and DNSSEC is unsigned.

I then used WhatWeb to identify the technologies running the website. The results identified Apache, WordPress 7.1.4, WordPress Download Manager 3.3.76, Bootstrap, jQuery 3.7.1, the server's real IP address (192.232.216.135), and a contact email (info@networkwalks.com).

Using Nslookup, I resolved the domain name to its IP address, confirming 192.232.216.135, matching the IP found via WhatWeb.

I used Curl with the -I option to inspect the HTTP response headers. The site returned HTTP/2 200, revealing the Apache server banner, a secure/HttpOnly session cookie, caching headers consistent with the HostGator hosting, and a Link header exposing the WordPress REST API endpoint /wp-json/. No HSTS, X-Frame-Options or Content-Security-Policy headers were present.

Next, I used Wafw00f to determine whether a Web Application Firewall was protecting the website. The result identified ModSecurity (SpiderLabs), detected with only two requests.

Finally, I used DNSRecon to enumerate DNS records. The results showed the SOA and NS records, an MX record pointing to the same IP as the website, an SPF record using a soft-fail (~all) policy, 8 cPanel-related SRV records, and — notably — that both authoritative name servers have open recursion enabled, a finding worth flagging as a possible DNS amplification risk.

4.2 Footprinting with Maltego (W2-PM3)

For the second module, I installed Maltego Graph (Desktop) 4.14.0 on Windows and activated it with a free Maltego ID on the Basic plan (200 credits, renewing 1 December 2026). I added a Domain entity to a new graph and renamed it to networkwalks.com.

I then ran three Utilities transforms on the domain entity, one at a time: To Email address [From whois info], To Email Addresses [Search Engine], and To Emails @domain [Search Engine]. Each new email appeared as an entity linked to the domain on the graph.

The final graph returned two distinct email addresses: info@networkwalks.com (returned by both search-engine transforms, so drawn twice on the graph) and abuse@godaddy.com (returned by the WHOIS transform — this belongs to the domain registrar, GoDaddy, not the target organisation itself). The three transforms together consumed 20 of my 200 available credits.

The first run of the WHOIS transform failed with the error "Transform canceled, server not trusted," caused by the same connectivity issue that had earlier stopped the Maltego login wizard from generating a login link. Re-running the same transform after the connection issue cleared completed successfully in 4.2 seconds with 2 entities returned.

Footprinting with Maltego: networkwalks.com

Each new email appeared as an entity linked to the domain. The final graph shows info@networkwalks.com (returned by both search-engine transforms, so drawn twice) and abuse@godaddy.com.

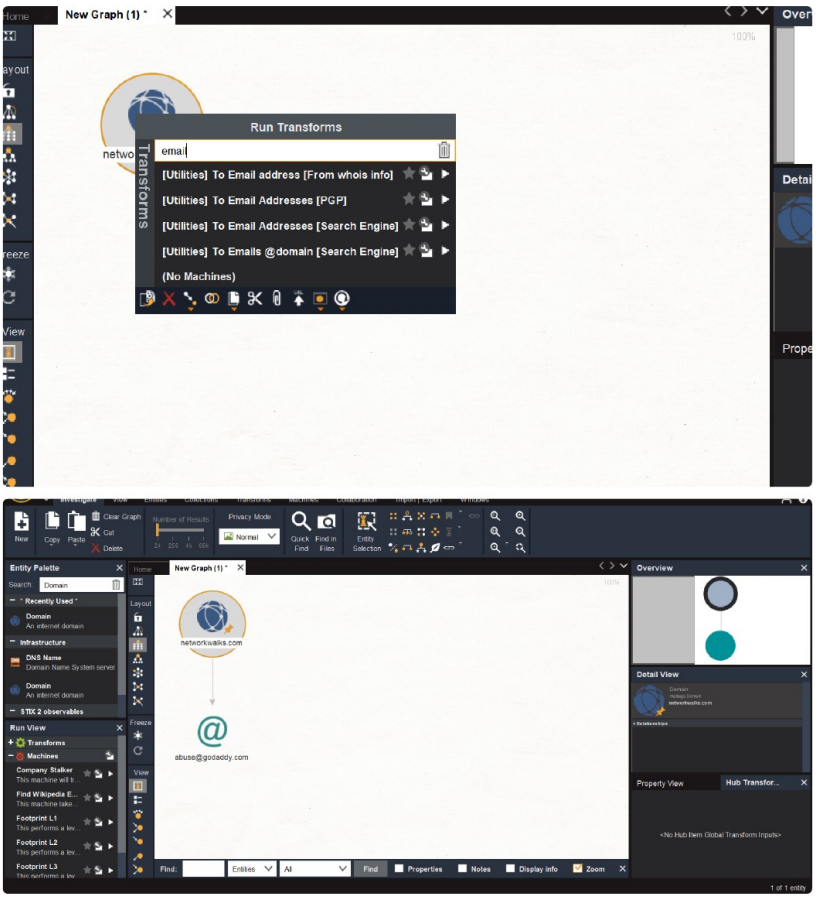


Figure: Maltego graph showing the Utilities transforms run on the networkwalks.com domain entity, and the resulting email entities (info@networkwalks.com, abuse@godaddy.com) linked to it.

4.3 Footprinting with theHarvester (W2-PM4)

For the third module, the assigned target was a different domain, microsoft.com. I ran theHarvester 4.11.1 on Kali Linux. Like the other modules, theHarvester only queries public sources and does not access the target directly.

Task 1 restricted the search to a single source, Baidu, with a limit of 1000 results:

```
theHarvester -d microsoft.com -l 1000 -b baidu | tee task1_baidu.txt
```

This run completed without errors but found no IPs, emails, people or hosts — an empty result from that one source.

Task 2 repeated the search using all available sources, with a limit of 50:

```
theHarvester -d microsoft.com -l 50 -b all | tee task2_all.txt
```

Several sources reported a missing API key and were skipped, but the tool continued with the sources that did not require one, including Baidu, Certspotter, crt.sh, Commoncrawl, DuckDuckGo, Hackertarget, Hudson Rock, Otx, Rapiddns, Mojeek and Robtex. This run found 3 email addresses (dotnet-docker-bot@microsoft.com, opencode@microsoft.com, secure@microsoft.com — all role-based or automated mailboxes rather than named staff), 868 hosts (sub-domains such as account, careers, cdn, dotnet and download), and 147 IPs.

Run	Source	Limit	Emails	Hosts	IPs
Task 1	Baidu	1000	0	0	0
Task 2	All sources	50	3	868	147

These results differ from the course's sample output, which reported one email found via Baidu alone — a reminder that theHarvester depends on public sources that change over time, and that results can vary between runs.

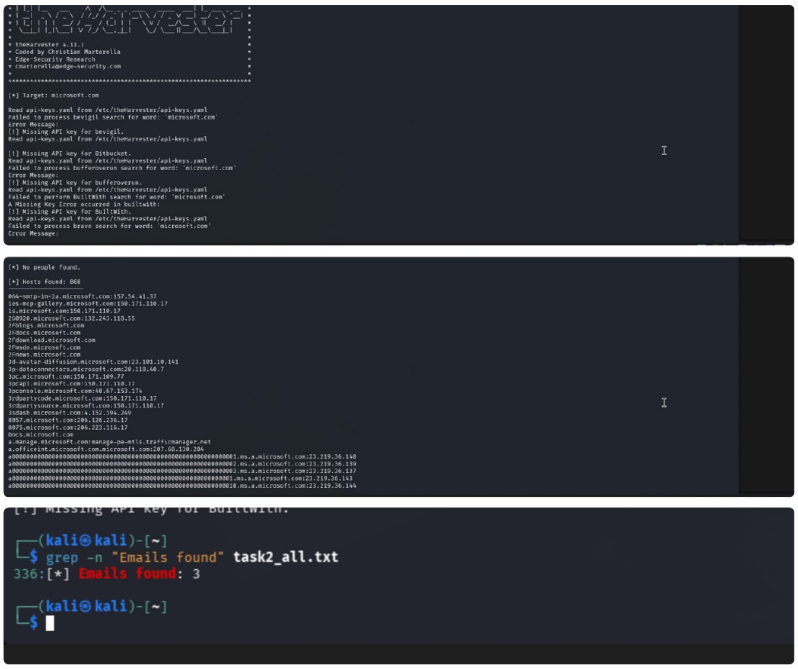
Footprinting with theHarvester: microsoft.com

Task 2: all sources, limit 50

The search was repeated with all sources and a limit of 50, saving the output to task2_all.txt:

```
theHarvester -d microsoft.com -l 50 -b all | tee task2_all.txt
```

The run took several minutes. Many sources reported a missing API key (Figure 4), and the tool carried on with the sources that did not need one, including Baidu, Certspotter, crt.sh, Commoncrawl, DuckDuckGo, Hackertarget, Hudson Rock, Otx, Rapiddns, Mojeek and Robtex. The summary reports 868 hosts (Figure 5), and a search of the saved file confirms the emails count (Figure 6).



Page 3 of 4

Figure: theHarvester Task 2 output (all sources, limit 50) showing the 868 hosts found, and a grep confirming 3 emails in the saved output file.

4.4 Network Scanning with Zenmap (W2-PM5)

For the final module, I used Zenmap to perform network discovery on my own local network. The practical required me to identify my local IP address and subnet, discover live hosts, identify their IP and MAC addresses, and generate a network topology.

I first used the Windows ipconfig command to identify my local IP address and LAN subnet. My active Wi-Fi adapter showed IPv4 address 192.168.100.177 with subnet mask 255.255.255.0, giving a subnet of 192.168.100.0/24. (A second, virtual adapter — 192.168.56.1, with no default gateway — was correctly excluded as it did not represent the real LAN connection.)

I entered 192.168.100.0/24 into Zenmap and selected Ping Scan to identify active hosts:

```
nmap -sn 192.168.100.0/24
```

The scan completed in 11.10 seconds and identified 3 live hosts:

- 192.168.100.1 — the router / default gateway (MAC 74:A0:63:B5:52:30, Huawei Technologies)
- 192.168.100.176 — an unidentified device on the LAN (MAC 32:89:2C:A7:08:E2, vendor unknown)
- 192.168.100.177 — my own PC, the scanning machine

Nmap does not report a MAC address for the scanning machine itself, since a host does not ARP its own interface; that MAC would instead need to be read from ipconfig /all.

After completing the scan, I opened the Topology section in Zenmap, enabled the legend, reviewed it, and saved the network topology in PDF format to my desktop as required by the practical task.

5. Risk Analysis / Impact

Based on the information collected across all four footprinting/OSINT modules and the one scanning module, I identified the following potential risks.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Web technology information exposed	WhatWeb identified WordPress 7.1.4 and WP Download Manager 3.3.76	Attackers may match exact versions against known vulnerabilities	Medium
2	Server IP address identifiable	Nslookup/WhatWeb resolved the domain to 192.232.216.135	Allows direct scanning and infrastructure mapping	Low
3	HTTP technical information exposed	Curl returned response headers and exposed /wp-json/ (REST API)	Assists fingerprinting and content enumeration	Low
4	DNS infrastructure exposed, open recursion	DNSRecon showed DNS/mail/SRV records; both name servers allow open recursion	Supports infrastructure profiling; open recursion risks DNS amplification abuse	Medium
5	Organisational email addresses exposed	Maltego found info@networkwalks.com; theHarvester found 3 role-based emails for microsoft.com	Enables phishing and password-spray targeting; low sensitivity since role-based	Low–Medium
6	Large sub-domain footprint	theHarvester found 868	Each sub-domain is an	Medium

	exposed	hosts/sub-domains for microsoft.com using free sources only	additional system an attacker could probe, including forgotten ones	
7	WAF technology identifiable	Wafw00f identified ModSecurity (SpiderLabs) in 2 requests	Reveals the site's defensive posture, shaping attacker tactics	Low
8	Live hosts visible on local network	Zenmap identified 3 live hosts on my own LAN	Unknown or unauthorized devices could potentially be present on a network	Medium

The risks above are observations from passive footprinting, OSINT gathering and host discovery exercises, not confirmed vulnerabilities.

These four modules primarily involved information gathering and host discovery. No exploitation or vulnerability validation was performed. Therefore, the presence of information such as a software version, IP address, email address or DNS record does not by itself mean a system is vulnerable. Further authorized security testing would be required to confirm any actual vulnerability.

6. Recommendations

Based on the observations from all four activities, I recommend the following security improvements:

1. Review publicly exposed technology information — organizations should regularly review what information about their web technologies, CMS and plugins is publicly visible.

2. Keep software updated — CMS platforms, plugins and other web technologies should be regularly updated and reviewed against current security advisories.

3. Review HTTP headers — HTTP response headers should be reviewed to determine whether unnecessary technical information (such as exposed API endpoints) is being disclosed, and missing security headers (HSTS, CSP, X-Frame-Options) should be added.

4. Review DNS records regularly — DNS records should be checked periodically to ensure that only required information and services are publicly exposed, and name servers should have open recursion disabled or restricted to trusted clients.

5. Properly configure and monitor the WAF — keep the WAF (ModSecurity) enabled and tuned, since it already blocks naive attacks.

6. Limit and monitor publicly discoverable email addresses — prefer role-based mailboxes behind spam/phishing filtering (SPF, DKIM, DMARC) over named individual addresses where possible, and tighten SPF to a hard-fail (-all) where mail flows allow.

7. Maintain a sub-domain inventory — periodically enumerate your own domain with OSINT tools such as theHarvester to find forgotten or unmanaged sub-domains, and retire ones no longer in use.

8. Perform regular internal network discovery — organizations should periodically scan their own networks to identify active devices.

9. Investigate unknown devices — any unexpected device discovered during network scanning (such as 192.168.100.176 in this report) should be investigated and verified.

10. Maintain network documentation — network topology and device information should be documented and updated regularly.

11. Perform security testing with authorization — reconnaissance, OSINT gathering and scanning should only be performed against systems and networks where appropriate authorization has been provided.

7. Conclusion

During Week 2 of my Cybersecurity & Ethical Hacking internship, I completed four practical activities covering footprinting, OSINT gathering and network scanning.

In the Kali tools activity (W2-PM1), I used six command-line tools to build a technical profile of networkwalks.com. I learned how WHOIS can provide domain information, WhatWeb can identify web technologies, Nslookup can resolve domain names, Curl can inspect HTTP headers, Wafw00f can identify a WAF, and DNSRecon can provide additional DNS information.

In the Maltego activity (W2-PM3), I learned how a graph-based OSINT tool links discovered entities — in this case, email addresses — directly to the target domain, making relationships (such as an email belonging to the registrar rather than the organisation itself) visually clear in a way a command-line tool output does not.

In the theHarvester activity (W2-PM4), I saw how a single automated tool can aggregate many public sources at once, and how dramatically the completeness of results depends on which sources are queried and whether API keys are configured — the single-source Baidu run found nothing, while the all-sources run surfaced hundreds of sub-domains and several email addresses.

In the network scanning activity (W2-PM5), I used Zenmap to identify my local network configuration and discover active hosts, collect IP and MAC address information, and create a network topology diagram.

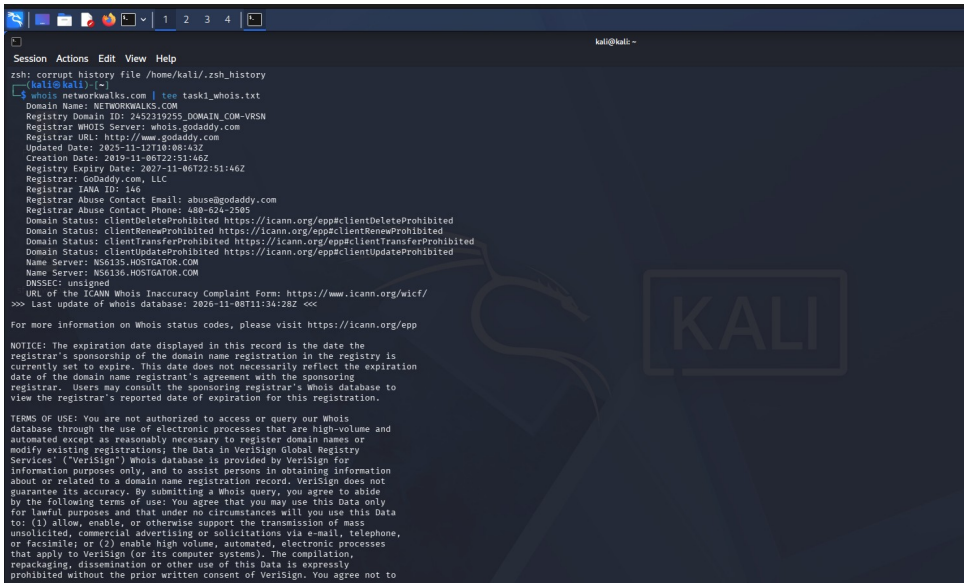
Together, these exercises showed me that information gathering is a substantial part of cybersecurity, and that it comes in several distinct flavours — command-line tools, graph-based OSINT platforms, and automated harvesters — each surfacing overlapping but not identical findings. Even before attempting to exploit a system, a security professional can learn a significant amount about an environment and its people by carefully combining results from several passive sources.

I also learned that technical findings should be documented clearly, and that a good cybersecurity report should explain what was performed, what was discovered, what the observation means, what risk it may create, and what can be done to reduce that risk.

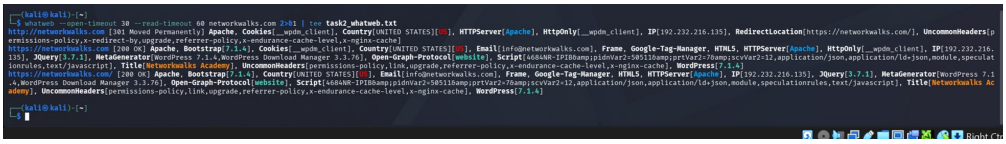
Finally, I learned that reconnaissance, OSINT gathering and scanning must always be performed within an authorized scope — the course-assigned domains for passive footprinting, and my own network for the one active scanning module. These activities were completed as part of the assigned educational cybersecurity lab.

8. Evidences Collected

W2-PM1 — Kali Tools



whois networkwalks.com



whatweb networkwalks.com

```
┌──(kali㉿kali)-[~]
└─$ nslookup networkwalks.com | tee task3_nslookup.txt
;; communications error to 8.8.8.8#53: timed out
;; communications error to 8.8.8.8#53: timed out
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
Name:   networkwalks.com
Address: 192.232.216.135


┌──(kali㉿kali)-[~]
└─$
```

nslookup networkwalks.com



curl -I https://networkwalks.com

```
┌──(kali㉿kali)-[~]
└─$ wafw00f networkwalks.com 2>&1 | tee task5_wafw00f.txt

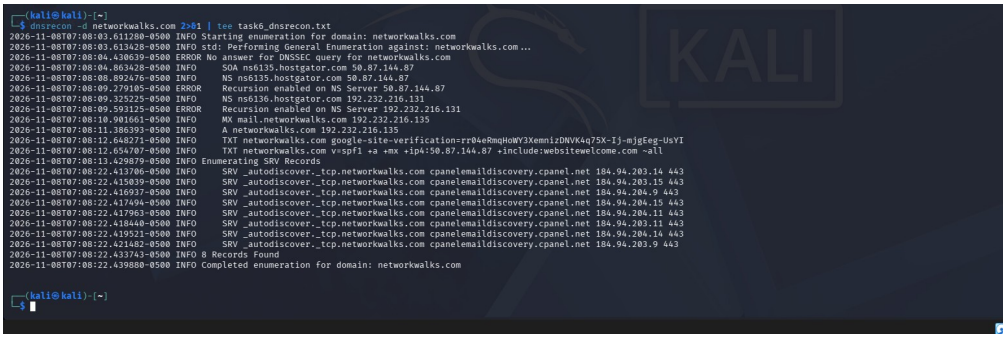
                ?                ,.   (   .      )        .      "
              __              ??          ("     ) )'     ,.        )  . (`     ``
     (___()``;   ???          .; )  ' (( (" )    ;(,     ((  (  ;)  "  )")
     /,___ /`                 _"., ,._ _.,)_(..,( . )_  _' )_') (. _..( ' )
     \\   \\                |____|____|____|____|____|____|____|____|____|

                                ~ WAFW00F : v2.4.2 ~
                    ~ Sniffing Web Application Firewalls since 2009 ~

[*] Checking https://networkwalks.com
[+] The site https://networkwalks.com is behind ModSecurity (SpiderLabs) WAF.
[~] Number of requests: 2

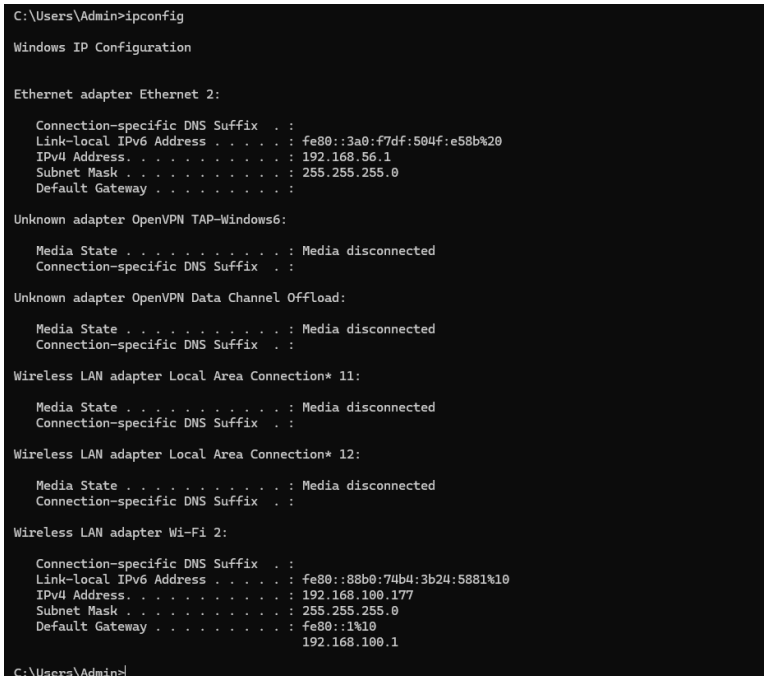
┌──(kali㉿kali)-[~]
└─$
```

wafw00f networkwalks.com

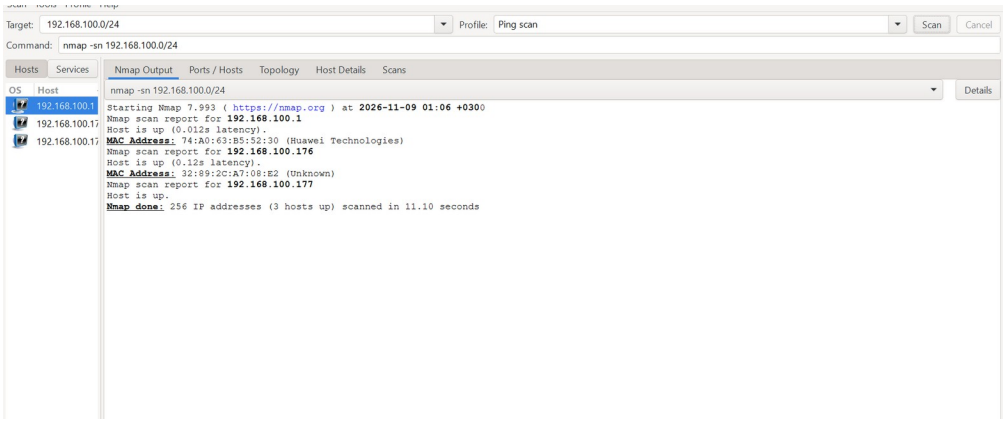


dnsrecon -d networkwalks.com

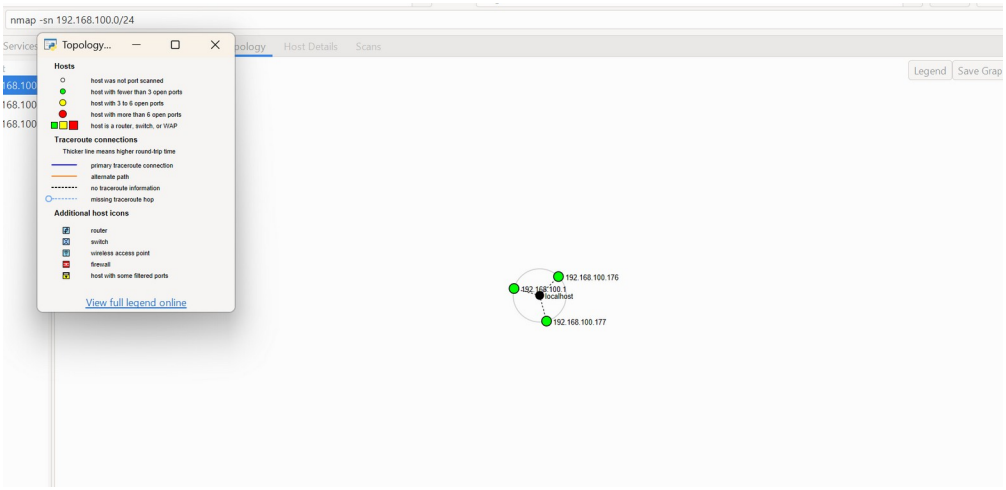
W2-PM5 — Zenmap



ipconfig — local IP and subnet



nmap -sn 192.168.100.0/24 — ping scan results



Zenmap topology view with legend

Full topology PDF saved separately as Zenmap_Topology.pdf.

-End-

👤 Author

Sheila Chepkoech

Cybersecurity Professional — B084-Networkwalks

LinkedIn: https://www.linkedin.com/in/sheila-chepkoech-b59b902b4

📌 Project Information

Program Name: Cybersecurity program at Networkwalks | Week: 02